

./02-architecture/DOC-08-Multi-Tenancy.md

DOC-08: Multi-Tenancy Architecture

Version: 1.0 | **Status:** APPROVED | **Date:** 2026-08-27 **Purpose:** Detail the multi-tenant SaaS capabilities.

Owner: Senior Software Architect

Tenant Model

- **Tenant:** An `Organization` represents a tenant.
- **Isolation Strategy:** Application-level isolation (logical schema isolation). Every tenant-owned table has an `organization_id`.
- **Identity:** Users exist globally but have specific `organization_members` records associating them with tenants. This supports future cross-tenant memberships.

Tenant Context Resolution

1. Client sends request with Bearer Token.
2. Authentication middleware verifies token.
3. System identifies User and their active `Organization` context.
4. Authorization guard checks permissions against the active context.
5. All database queries automatically append `WHERE organization_id = currentOrganizationId`.

Cross-Tenant Access Prevention

Client-provided `organization_id` in request bodies is **never** blindly trusted. The backend exclusively uses the authenticated user's resolved tenant context for data scoping.